

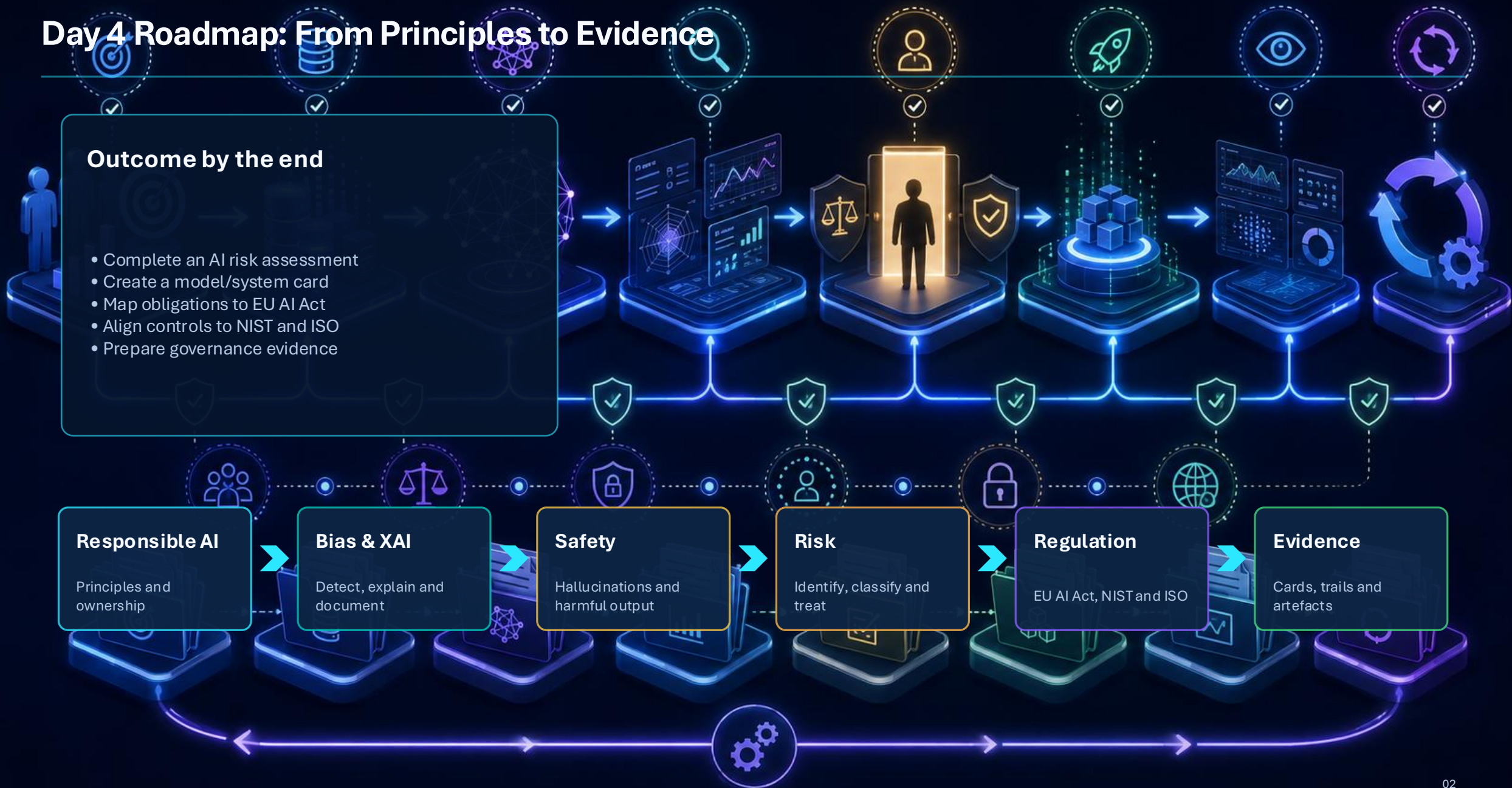
Responsible AI, Governance, Risk & Regulatory Alignment

A practical journey from principles to risk controls, regulatory mapping, governance evidence and a hands-on governance clinic.

**Responsible AI → Risk Management → Regulatory
Alignment → Governance Evidence**



Day 4 Roadmap: From Principles to Evidence



Responsible AI Foundations

Responsible AI converts values into engineering, operational and governance decisions.

Fairness

Avoid unfair treatment

Transparency

Make behavior understandable

Accountability

Define owners and approvals

Privacy

Protect sensitive data

How to apply it

- Define intended use and users
- Identify impacted stakeholders
- Convert principles into controls
- Assign ownership and review points
- Document risks and residual risk

Principle → Control → Evidence

Example: privacy → data minimization, PII redaction, access logs → policy, test reports and audit trail.

Bias Management: Detect, Assess, Mitigate

Theory

- Bias appears in data, labels, features, prompts and feedback loops
- Fairness is context-specific and must be defined for the use case
- Mitigation requires measurement before and after controls

Data review

Representation, missingness, proxies



Metric choice

Group outcomes and error rates



Mitigation

Sampling, prompts, thresholds, controls



Monitoring

Drift, complaints, adverse impact

Control objective

Reduce unfair outcomes and document residual risk.

Explainability & Transparency

What needs to be clear

- What the system is designed to do
- What data and model are used
- Why a decision or output occurred
- Limitations, risks and human review path

Model card

Model purpose, metrics, constraints, evaluation results.

System card

End-to-end use case, controls, users, risks, monitoring.

User notice

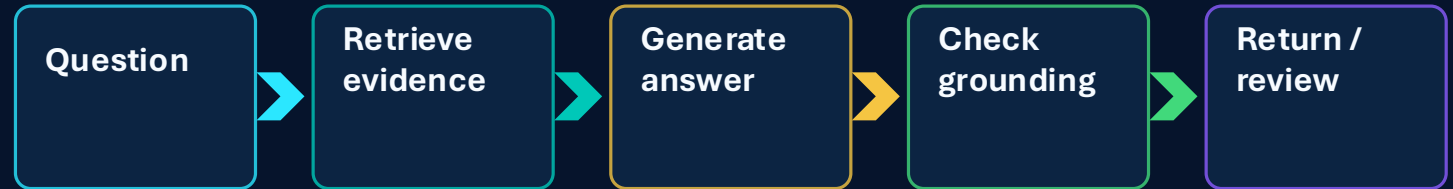
What users should understand before relying on output.

Transparency is not only a technical explanation; it is usable documentation for business, risk, legal, operations and affected users.

Hallucination Management: Ground Before You Generate

Problem

- LLMs may produce confident but unsupported answers
- RAG reduces risk, but retrieval and citations must be verified
- High-impact advice needs human review and escalation



Controls

Grounded generation • citation validation • unsupported-claim detection • refusal when evidence is missing • HITL for high-risk topics.

Content Safety & Human Oversight

Content safety covers

- Harmful, violent, hateful or illegal content
- Audience appropriateness and context
- Refusal and safe completion patterns
- Escalation for sensitive or high-impact cases

Input safety

Detect risky user request before model call.

Output safety

Validate model response before release.

Human oversight

Review uncertain or high-impact responses.

Decision pattern

ALLOW

BLOCK

REVIEW

ESCALATE

Controls should be proportional: low-risk outputs can be automated, uncertain cases go to review, and harmful outputs are blocked.

AI Risk Management Process

Risk workflow

- Identify risk events and impacted users
- Classify severity and likelihood
- Treat with controls and owners
- Accept residual risk only after approval
- Monitor incidents, drift and control failures

Risk should be managed as an operating process, not as a one-time checklist.

Identify

Assess

Treat

Approve

Monitor

EU AI Act: Risk-Based Regulatory Thinking

Key idea

- Regulation classifies AI by risk and impact
- Higher-risk systems require stronger obligations
- Teams need documentation, controls, monitoring and human oversight



Delivery responsibilities

Classify use case • map obligations • document controls • retain evidence.

NIST AI RMF: Govern, Map, Measure, Manage

The NIST AI RMF provides a practical structure for identifying, measuring and managing AI risks across the lifecycle.

Governance lens

- Set accountability and policies
- Map context and intended use
- Measure performance, safety and bias
- Manage residual risk and change

Govern

Manage

Map

Measure

ISO Standards: From Controls to Management System

Core standards

- ISO/IEC 42001: AI management system
- ISO/IEC 23894: AI risk management guidance
- Use standards to make governance repeatable and auditable

Plan

Policies and objectives

Do

Implement controls

Act

Improve and correct

Check

Measure and audit

Management system view

Governance becomes a repeatable operating model with evidence, reviews and continual improvement.

Governance Evidence: Prove the Controls Exist

Evidence artefacts

- AI risk assessment
- Model card and system card
- Evaluation and bias reports
- Approval logs and audit trails
- Monitoring logs and incident records

Use case register

Risk record

Model card

System card

Audit trail

Oversight plan

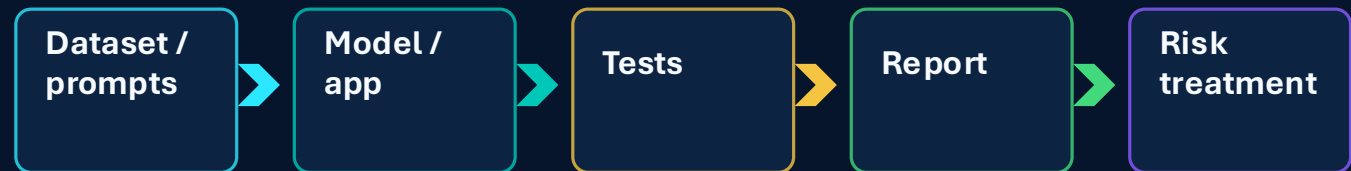
Evidence folder

A single traceable package for review, audit, client assurance and continuous improvement.

Tool Spotlight: Giskard for Testing and Governance Evidence

Where it fits

- Evaluate model behavior before release
- Test hallucination, robustness and bias scenarios
- Generate findings that support governance evidence
- Use results to tune prompts, datasets, guardrails and policies



Tool results should be treated as evidence inputs, not as automatic approval. Governance still requires owner review and sign-off.

Hands-on Governance Clinic

Clinic deliverables

- AI risk assessment
- Model/system card
- Human oversight plan
- EU AI Act mapping
- Governance evidence pack

Practical scenario: customer-support GenAI or RAG/agentic workflow. The goal is not only to build the system; the goal is to make it governable.

1. Select use case

2. Identify risks

3. Define controls

4. Map obligations

5. Prepare evidence

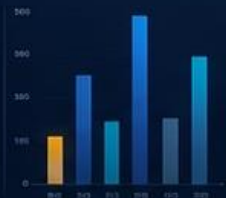
Close

Day 4 Recap: Governance-Ready AI

Governance-ready AI is explainable, risk-assessed, controlled, monitored and supported by evidence.



- Responsible AI principles translated into controls
- Bias, explainability, hallucination and safety evaluated
- Risk classified and treatment plan defined
- EU AI Act, NIST AI RMF and ISO mapped
- Evidence pack prepared for audit and review
- Human oversight and monitoring ready for operation



Final mindset

Do not stop at model performance. Add governance, evidence and accountability.

Next: Day 5

Red teaming, evaluation, monitoring, Secure SDLC and capstone.